情報処理安全確保支援士試験　科目A-2　中分類24 情報セキュリティマネジメント　#06

セキュリティの考え方とリスクマネジメント

何を守るのか（7つの特性）、どう守るのか（原則）、どこまで守るのか（リスクの評価と対応）

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、JIS Q 27000・27001・31000、ISO/IEC 27005 など）を書いた。過去問は IPA 公開の午前 II 。金額の例は Claude が作った

全体像 シラバス案 中分類24 小分類1「情報セキュリティの考え方」・小分類2「リスクマネジメント」

1 情報セキュリティの考え方
CIA＋真正性・責任追跡性・否認防止・信頼性、多層防御、バイ・デザイン／デフォルト、最小権限、need-to-know、フェイルセーフ／セキュア、責任共有モデル

2 リスクの見つけ方と測り方
情報資産台帳、リスクの種類、ALE・SLE・ARO、4つのアプローチ、リスク基準、特定・分析・評価、リスク所有者

3 リスク対応
回避・低減・移転・保有、リスク対応計画、リスク登録簿、残留リスクと受容の承認

過去の午前 II での出方

テーマ	出た回
JIS Q 27000 の用語の定義	R5秋・R7春
フールプルーフなど設計の名前	R4春

午前 II では少ないが、**科目B（午後）でリスクアセスメントの手順や対応の選択**を問われる土台。AP・SG の午前でも頻出。

定義の**入れ替え**が定番のひっかけ：脅威⇔脆弱性、リスク評価⇔リスク対応。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類24／IPA 午前 II 令和5年度秋期 問11・令和7年度春期 問10・令和4年度春期 問22

第1章

情報セキュリティの考え方

守る特性を言い当て、守り方の原則を区別する。

7つの特性：CIA と、それを補う4つ

特性	JIS Q 27000 の意味（要約）	損なう例	守る手段
機密性	認可されない者に使用させず、開示しない	漏えい・盗聴	アクセス制御・暗号化
完全性	正確で完全である	改ざん・誤更新	ハッシュ・署名
可用性	認可された者が要求したとき使える	DoS・故障	冗長化・バックアップ
真正性	主張どおりのものである	なりすまし	認証・署名
責任追跡性	動作をその主体だけに一意にさかのぼれる	共有アカウント	個人 ID・ログ
否認防止	事象・行為とその主体を後から否認させない	「送っていない」	署名＋タイムスタンプ
信頼性	意図した動作・結果が一貫している	誤動作	テスト・品質管理

否認防止に MAC は不十分：共通鍵なので受信者も同じ MAC を作れる → 第三者に「送信者が作った」と示せない（#15）。

出典：JIS Q 27000:2019 用語の定義（情報セキュリティ・機密性・完全性・可用性・真正性・否認防止・信頼性など）。要約は Claude

守り方の原則：似た言葉を区別する

原則	一言で
多層防御	性質の違う層を重ねる（入口・内部・出口）
セキュリティ・バイ・デザイン	企画・設計から組み込む
セキュア・バイ・デフォルト	初期設定のままで安全
最小権限の原則	操作の権限を必要最小限に
need-to-know	知る必要のある情報だけ見せる
攻撃対象領域の最小化	入口を減らす

多層防御の典型



同じファイアウォールを2台並べても、同じ方法で破られる → 多層防御とはいえない。

最小権限 vs need-to-know：「何ができるか」と「何を知ってよいか」。部長でも関係ない部署の設計書は見られない＝need-to-know。

出典：IPA「支援士試験 シラバス（案）」中分類24 用語例／NISC「セキュリティ・バイ・デザイン」／CISA「Secure by Design」（2023）

故障・誤操作に備える設計の名前

名前	故障・誤りが起きたら	例
フェイルセーフ	安全（人命・設備）の側へ	停電で非常口の錠が開く
フェイルセキュア	セキュリティ（閉じる・拒否）の側へ	停電でサーバ室の錠は閉じたまま
フェールソフト	機能を落として動き続ける	片方のエンジンで飛ぶ
フォールトトレランス	冗長化で全機能を続ける	二重化したサーバ
フールプルーフ	誤操作をさせない・知らせる	誤入力のメッセージ

R4春 問22:「規定外の無効なデータが入力されたとき、誤入力のメッセージを出して正しい入力を促す」＝**フールプルーフ**。

認証サーバに届かないとき、ログインを**許す**のはフェイルオープン、**拒む**のはフェイルセキュア（フェイルクローズ）。セキュリティでは拒む側が基本。

出典：IPA 午前 II 令和4年度春期 問22／IPA「支援士試験 シラバス（案）」用語例「フェイルセーフ／フェイルセキュア」

責任共有モデル：どこまでが利用者の責任か

層	オンプレミス	IaaS	PaaS	SaaS
データ・アカウント・アクセス権	利用者	利用者	利用者	利用者
アプリケーション	利用者	利用者	利用者	事業者
ミドルウェア・ランタイム	利用者	利用者	事業者	事業者
OS	利用者	利用者	事業者	事業者
仮想化・物理・設備	利用者	事業者	事業者	事業者

どの形態でも**データとアクセス権は利用者**。クラウドの漏えいの多くは、公開設定の誤りなど利用者側の範囲で起きる（#18）。

外部委託・クラウドの利用：選ぶ（ISMAP・認証）→ 契約（要件・再委託・監査権・報告）→ 監視 → 終了（返却・消去）。委託しても**委託元の責任は残る**。

出典：IPA「支援士試験 シラバス（案）」用語例「クラウドサービスの責任共有モデル」「外部委託やクラウドサービスの利用時における情報セキュリティ」。表は一般的な分担を Claude が単純化

第2章

リスクの見つけ方と測り方

特定 → 分析 → 評価。定義を入れ替える問題に注意。

リスクマネジメントの流れ（JIS Q 31000）

適用範囲・状況・基準の確定
リスク基準を決めておく

↓

リスクアセスメント
① リスク特定 → ② リスク分析 → ③ リスク評価

↓

リスク対応
回避・低減・移転・保有 → 対応計画

すべての段階を囲む：コミュニケーション及び協議／モニタリング及びレビュー／記録作成及び報告

段階	JIS Q 27000 の定義（要約）
リスク特定	発見・認識・記述。リスク源・事象・原因・起こりうる結果の特定を含む
リスク分析	特質を理解し、**リスクレベル**を決定する
リスク評価	分析結果を**リスク基準と比較**し、受容・許容できるかを決める
リスク対応	リスクを**修正**する
脅威	損害を与えうる望ましくないインシデントの**潜在的な原因**
脆弱性	脅威に付け込まれうる資産・管理策の**弱点**

出典：JIS Q 31000:2019 図4 プロセス／JIS Q 27000:2019 用語の定義。要約は Claude

R7春 問10（R5秋 問11 と同じ）：定義の入れ替えを見抜く

	選択肢の文	本当は何の定義か
ア	脅威とは、一つ以上の要因によって付け込まれる可能性がある、資産又は管理策の弱点	脆弱性
イ	脆弱性とは、システム又は組織に損害を与える可能性がある、望ましくないインシデントの潜在的な原因	脅威
ウ	リスク対応とは、受容・許容可能かを決定するために、リスク分析の結果をリスク基準と比較するプロセス	リスク評価
エ	リスク特定とは、リスクを発見、認識及び記述するプロセス（リスク源、事象、原因、結果の特定を含む）	正しい

覚え方：脅威は「原因」、脆弱性は「弱点」。評価は「基準と比べる」、対応は「修正する」。

リスク評価の英語は **Risk Evaluation**。リスクアセスメント（Assessment）は特定・分析・評価の**全体**。

出典：IPA 午前 II 令和7年度春期 問10・令和5年度秋期 問11／JIS Q 27000:2019

定量的リスク分析：ALE = SLE × ARO

SLE ＝ 資産の価値 × 暴露係数（EF）

ALE ＝ SLE × ARO（年間発生率）

計算の例

資産の価値	4,000 万円
暴露係数 EF	25%
SLE	1,000 万円
ARO（4年に1回）	0.25
ALE	**250 万円/年**

対策の費用対効果

1. 対策で ARO が 0.25 → 0.1 になる
2. 対策後の ALE ＝ 1,000 × 0.1 ＝ 100 万円
3. 減る損失 ＝ 250 − 100 ＝ **150 万円/年**
4. 対策の費用 80 万円/年 < 150 万円 → **導入する価値あり**

> 定量的分析は比べやすいが、ARO や EF の見積もりが難しい。定性的分析（高・中・低、リスクマトリックス）は手軽だが人によって差が出る。

出典：IPA「支援士試験 シラバス（案）」用語例「年間予想損失額（ALE），単一損失予想額（SLE），年間発生率（ARO）」。数値の例は Claude が作った

リスク分析の4つのアプローチとリスクマトリックス

アプローチ	方法	長所／短所
ベースライン	既存の基準・管理策の一覧と比べる	速い／固有のリスクを見落とす
非形式的	専門家の経験と判断	手軽／偏る
詳細リスク分析	資産ごとに価値・脅威・脆弱性を評価	精密／時間と費用
組合せ	重要部分は詳細、他はベースライン	バランスが良い

リスクマトリックス（定性的分析）

影響＼起こりやすさ	低	中	高
大	中	高	高
中	低	中	高
小	低	低	中

マスの値＝**リスクレベル**。これを**リスク基準**（例：「高」は必ず対応、「低」は受容）と比べるのがリスク評価。

出典：IPA「支援士試験 シラバス（案）」用語例「リスク分析のアプローチ」「リスクマトリックス」／ISO/IEC TR 13335-3

資産・リスクの種類・リスクの責任者

リスクの種類（シラバス案の例）

オペレーショナル	業務の誤り・障害・内部不正
サプライチェーン	取引先・委託先からの被害（#05）
外部サービス利用	クラウド・SaaS の障害や設定の誤り
SNS の情報発信	炎上・誤投稿・なりすましアカウント
地政学的	国家間の対立による攻撃・規制

情報資産台帳（何を持っているか）→ **リスク登録簿**（何が起こりうるか、だれが責任者か、対応はどこまで進んだか）。

リスク所有者：リスクを運用管理する責任と権限をもつ人。JIS Q 27001 6.1.3 f) は、リスク対応計画と**残留リスクの受容**について、リスク所有者の承認を得ることを求める。

リスク態度：リスク選好（どれだけのリスクを取ってよいか）、リスク回避的な態度。

出典：IPA「支援士試験 シラバス（案）」中分類24 小分類2 用語例／JIS Q 27001:2023 6.1.2・6.1.3

第3章

リスク対応

4つの選択肢と、必ず残るリスクの扱い。

リスク対応の4つの選択肢

選択肢	すること	例
回避	原因となる活動をやめる・始めない	カード情報を自社で持たない
低減（軽減）	起こりやすさ・影響を小さく	MFA・暗号化・バックアップ
移転（共有）	他者と分け合う	サイバー保険・外部委託
保有（受容）	判断して受け入れる	損失が小さく対策が割高

起こりやすさ × 影響で選ぶ目安

	起こりにくい	起こりやすい
影響 大	移転	回避・低減
影響 小	保有	低減

保険は**お金**を移すだけ。評判の低下・法的責任・業務の停止は移せない。

リスクコントロール（回避・低減）とリスクファイナンス（移転・保有）という分け方もある。

出典：JIS Q 31000:2019 6.5.2 リスク対応の選択肢／IPA「支援士試験 シラバス（案）」用語例「リスク対応の選択肢」。目安の表は一般的な整理を Claude がまとめた

対応計画・残留リスク・受容の承認



残留リスクは必ず残る。ゼロにはできない。気付いていないリスクも含みうる。

リスクコミュニケーション: 経営者・従業員・取引先などと、すべての段階で情報を共有し意見を交わす。

保有 ≠ 放置。分析・評価のうえで「受け入れる」と判断し、承認を得て、監視を続ける。把握していないのは対応ではなく管理の不備。

出典:JIS Q 27001:2023 6.1.3／JIS Q 31000:2019 6.2 コミュニケーション及び協議

まとめ：本番での問われ方

特性を当てる：共有アカウント→責任追跡性、署名の否定→否認防止、なりすまし→真正性。

設計の名前：誤入力→フールプルーフ、安全側へ→フェイルセーフ、閉じる側へ→フェイルセキュア。

JIS Q 27000 の定義：脅威＝原因、脆弱性＝弱点、評価＝比較、対応＝修正、特定＝発見・認識・記述。

計算：ALE＝資産価値×EF×ARO。対策の価値＝ALE の減少額 − 費用。

対応の分類：保険＝移転、やめる＝回避、対策＝低減、受け入れる＝保有。

ISMS の要求事項（4〜10 箇条）と管理策（附属書 A）は **#08** で。

出典：IPA 午前 II（このPDFの問題演習）／JIS Q 27000:2019・JIS Q 27001:2023・JIS Q 31000:2019